

Tempris Private Bug Bounty Framework

1. Program Overview

Tempris is a continuous threat exposure management (CTEM) platform developed by a Singapore-based cyber tech firm. Security is fundamental to our product. Before general release, we are partnering with select security researchers to stress-test our application. This Private Bug Bounty Framework outlines the scope, rules of engagement, and rewards for this aggressive testing phase.

2. Scope

In-Scope Targets:

- All API endpoints under `/api/*`
- React Frontend (SPA)
- SPEAK AI chatbot
- SPOTLIGHT report generator
- STRIKE simulation engine
- SCOUT scanner
- SPECTRUM EDIP engine
- STANDARD compliance module
- Asset Inventory
- GRC/ISO 42001 module
- TACF Audit Trail

Out-of-Scope Targets:

- Underlying infrastructure (VPS, Docker, PostgreSQL)
- Third-party APIs (e.g., FreeLLMAPI)
- Social engineering (phishing, vishing)
- Denial of Service (DoS/DDoS) attacks
- Physical security testing

3. Rules of Engagement

- **No Destructive Testing:** Do not delete, alter, or destroy data outside of test accounts.
- **No Data Exfiltration:** Do not extract sensitive or proprietary data from the system.
- **Report Before Disclosure:** All vulnerabilities must be reported to the Tempris team and patched before any public disclosure.
- **Test Accounts:** Test accounts for all roles (Superadmin, Admin, Analyst, Viewer, Read-only) will be provided. Do not compromise accounts belonging to other users.
- **Rate Limiting:** Rate limiting is active on authentication and API endpoints. Respect the rate limits to avoid disrupting the platform.

4. Vulnerability Classification (CVSS 4.0 Aligned)

- **Critical (9.0-10.0):** Remote Code Execution (RCE), Authentication Bypass, Full Data Breach.

- **High (7.0-8.9):** Privilege Escalation, Insecure Direct Object Reference (IDOR), Server-Side Request Forgery (SSRF).
- **Medium (4.0-6.9):** Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Sensitive Information Disclosure.
- **Low (0.1-3.9):** UI/UX bugs, minor misconfigurations without direct security impact.

5. Reward Tiers

This program operates on an equity-based partnership model, not cash bounties. Findings contribute to a holistic evaluation of potential security partnerships. High-impact discoveries will be directly tied to partnership equity negotiations.

6. Reporting Process

Please submit findings to our security team. Reports must include:

- **Title:** A clear, concise title.
- **Severity:** Estimated CVSS 4.0 score/category.
- **Steps to Reproduce:** Step-by-step instructions to recreate the vulnerability.
- **Impact:** Explanation of the potential business or security impact.
- **Screenshots/PoC:** Visual evidence or exploit code demonstrating the issue.

7. Legal Safe Harbor

Tempris commits to protecting good-faith security researchers. No legal action will be taken against individuals who conduct testing within the defined scope and adhere to the Rules of Engagement.

8. Already Patched Vulnerabilities

The following issues were identified in previous assessments and have been remediated. Reports on these specific issues will not be accepted:

- DEMO_MODE backdoor (removed)
- SSRF in SCOUT scanner (RFC1918, link-local, and loopback blocked)
- JWT secret fallback (fail-closed implementation in production)
- GRC/TES manipulation (server-side validation added)
- STRIKE endpoint IDOR (authorization guards and RBAC enforced)
- SPOTLIGHT IDOR (history filtered by user role)
- Audit hash chain verification (tamper detection activated)
- Brute-force attacks (5-attempt lockout implemented)

9. Testing Environment

- **Target URL:** `https://187.127.114.218`
- **API Documentation:** Available at `/docs` (requires authentication)

10. Contact

Submit all reports and inquiries to: `security@tempris.com`